

Rapport d'audit de sécurité - Application Android

Informations générales

- **Application** : DIVA (Damn Insecure and Vulnerable App)
 - **Package** : jakhar.aseem.diva
 - **Version** : 1.0
 - **Auditeur** : Sara Essaidi
-

Résumé exécutif

Une analyse de la surface d'attaque de l'application Android DIVA a été réalisée à l'aide de Drozer dans un environnement contrôlé.

L'audit a permis d'identifier plusieurs faiblesses de sécurité :

- Activités accessibles sans mécanisme de protection.
- Content Provider exporté sans permissions de lecture ou d'écriture.
- Application débogable (debuggable=true).
- Sauvegarde applicative autorisée (allowBackup=true).

La vulnérabilité la plus critique concerne le Content Provider NotesProvider qui expose des URI accessibles sans protection.

Méthodologie

Outils utilisés

- Android Studio Emulator
- Android Debug Bridge (ADB)
- Drozer 3.1.0
- Drozer Agent 3.1.0

Méthode

1. Installation de DIVA sur l'émulateur Android.
 2. Installation et configuration de Drozer Agent.
 3. Connexion via Drozer Console.
 4. Cartographie des composants Android exposés.
 5. Analyse du manifeste Android.
 6. Vérification des permissions.
 7. Identification des URI accessibles.
 8. Évaluation des risques.
 9. Mapping OWASP MASVS.
-

Cartographie des composants exposés

Type	Nom	Exporté	Protection
Activity	MainActivity	Oui	Aucune
Activity	APICredsActivity	Oui	Aucune
Activity	APICreds2Activity	Oui	Aucune
Service	Aucun	Non	N/A
Receiver	Aucun	Non	N/A
Provider	NotesProvider	Oui	Aucune

Découvertes principales

V1 - Activity APICredsActivity accessible sans protection

Description

L'activité APICredsActivity est exportée via un intent-filter et ne requiert aucune permission.

Impact

Un utilisateur ou une application tierce pourrait accéder directement à cette fonctionnalité.

Sévérité

Élevée

V2 - Activity APICreds2Activity accessible sans protection

Description

L'activité APICreds2Activity est accessible sans contrôle d'accès.

Impact

Exposition potentielle d'informations sensibles.

Sévérité

Élevée

V3 - NotesProvider exporté sans permissions

Description

Le Content Provider NotesProvider est exporté.

Aucune permission n'est définie :

- Read Permission : null
- Write Permission : null

URI identifiées :

content://jakhar.aseem.diva.provider.notesprovider/notes

content://jakhar.aseem.diva.provider.notesprovider/notes/

Impact

Accès non autorisé aux données exposées par le Provider.

Sévérité

Critique

V4 - Application débogable

Description

Le manifeste contient :

android="true"

Impact

Augmentation de la surface d'attaque.

Sévérité

Moyenne

V5 - Sauvegarde autorisée

Description

Le manifeste contient :

android="true"

Impact

Les données applicatives pourraient être récupérées via les mécanismes de sauvegarde Android.

Sévérité

Moyenne

Recommandations prioritaires

Priorité 1

Sécuriser NotesProvider :

- Ajouter des permissions de lecture et d'écriture.
- Désactiver l'export si non nécessaire.

Priorité 2

Restreindre l'accès aux Activities exposées :

- Utiliser android="false" lorsque possible.
- Implémenter des contrôles d'accès.

Priorité 3

Désactiver le mode debug :

android="false"

Priorité 4

Désactiver les sauvegardes :

android="false"

Conclusion

L'application DIVA présente plusieurs faiblesses classiques liées à l'exposition de composants Android et à l'absence de contrôles d'accès.

Les vulnérabilités observées sont cohérentes avec les objectifs pédagogiques de l'application et démontrent l'importance :

- du contrôle des composants exportés,

- de la protection des Content Providers,
- de la sécurisation du manifeste Android.